

NGCSECURITY

PENETRATION TEST

Evaluación de Seguridad Ofensiva - Plataforma Aurora Market

Organización	Aurora Market
Responsable	Alondra Juliana Gadea
Fecha	22/08/2026
Versión	1
Evaluación	Grey Box
Clasificación	Confidencial

DOCUMENTO CONFIDENCIAL

El contenido de este informe está destinado exclusivamente a la organización Aurora Market.



Índice

a. Resumen Ejecutivo	3
b. Alcance, Metodología y Tipo de Prueba	3
c. Resumen de Hallazgos	5
d. Detalle de Vulnerabilidades Detectadas	6
e. Plan de Remediación y Recomendaciones Estratégicas	8
f. Conclusión y Cierre	9

Resumen del documento

Evaluación externa de seguridad bajo modalidad Grey Box, orientada a validar el incidente reportado y detectar riesgos adicionales en la plataforma de comercio electrónico.

Hallazgo principal	AUR-01 · Control de acceso horizontal (IDOR)
Riesgo general	ALTO
Hallazgos	1 ALTA · 2 MEDIA · 2 BAJA



Resumen ejecutivo

A solicitud de la dirección de Aurora Market, se llevó a cabo una evaluación de seguridad sobre su plataforma de comercio electrónico durante la semana del 22-08-2026 al 29-08-2026 en los horarios menos operativos, 18:30hs.

El objetivo principal fue determinar si el incidente reportado por un usuario del aplicativo (visualización de los datos pertenecientes a otra cuenta) correspondía a una vulnerabilidad real, así como identificar otros riesgos que pudieran comprometer la información de los clientes o la operación del negocio.

Hallazgo principal

AUR-01

Durante el análisis se confirmó la existencia de una falla de control de acceso horizontal (IDOR) que permite a un usuario autenticado visualizar pedidos e información de otros usuarios manipulando el parámetro de su identificador en las solicitudes al servidor.

Además, se detectaron 3 vulnerabilidades de severidad media y 2 de baja.

Impacto general

El riesgo general encontrado se califica como ALTO debido a que la exposición de datos personales de más clientes de la aplicación podría verse comprometida derivando, no solo a vulnerar sus datos, sino a multas por incumplimiento de la LDPDPPP (Ley federal de protección de datos personales en posesión de los particulares) y pérdida de confianza de los usuarios.



Alcance autorizado

URL objetivo: <https://www.auroraMarket.mex.com.ar> y subdominios principales (auroraMarket.api)

Módulos evaluados: Login, búsqueda de productos, carrito de compras, proceso de pago, consulta de pedidos, panel de administración (panel de empleados)

Usuarios de prueba proporcionados: 1 cuenta cliente estándar, 1 cuenta empleado con permisos limitados.

Alcance, metodología y tipo de prueba

Fuera de alcance

- Redes sociales corporativas: Market_Online.
- Equipos personales de empleados y cuentas de correo externas (AuroraMarketMM@market.mex.com).
- Proveedores de pago y servicios externos.
- Ataques de denegación de servicio o fuerza bruta intensiva que afecte la disponibilidad de la aplicación. No realizar DoS ni DDoS.

Tipo de evaluación

Se llevará a cabo una prueba de tipo externa con la modalidad GREY BOX.

Metodología empleada

OWASP Testing Guide v4 y guías de PTES. Las pruebas manuales se contemplaron con herramientas automatizadas como NMAP (solo puertos web autorizados), Shodan, Burp Suite y ZAP.

Modalidad	Grey Box
Enfoque	Externo
Guías	OWASP Testing Guide v4 · PTES
Herramientas	NMAP · Shodan · Burp Suite · ZAP

Nota de alcance

Las pruebas se realizaron dentro de los límites definidos en el alcance autorizado, sin efectuar ataques de denegación de servicio ni fuerza bruta intensiva que afectara la disponibilidad de la aplicación.



Resumen de hallazgos por severidad

AUR-01	Control de acceso horizontal (IDOR)	ALTA	Consulta de pedidos	A Remediar
AUR-02	Exposición de información sensible en respuestas JSON	MEDIA	API por perfil	A Remediar
AUR-03	Falta de rate limiting en login (permite fuerza bruta)	MEDIA	Login	A Remediar
AUR-04	Cabeceras de seguridad HTTP faltantes (HSTS, X-Frame-Options)	BAJA	Global	A Remediar
AUR-05	Mensajes de error demasiado descriptivos (enumeración de usuario)	BAJA	Login	A Remediar

Distribución por severidad

ALTA	1 hallazgo · AUR-01
MEDIA	2 hallazgos · AUR-02 y AUR-03
BAJA	2 hallazgos · AUR-04 y AUR-05



AUR-01 · Control de acceso horizontal (IDOR) en pedidos

CRÍTICO / ALTA

CVSS Base Score (v3.1): 7.5 (Alta) · Vector: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Descripción

El endpoint GET /api/orders/details?oder_id=numeroUsuario no valida que el order_id pertenezca al usuario autenticado. Al modificar manualmente su valor mediante Burp Suite, el sistema devuelve los datos completos de cualquier otro pedido con los campos del objeto sin importar si el usuario no es propietario de los mismos.

Evidencia

1. Se inició sesión con el usuario común proporcionado (MARKETTEST).
2. Se ingresó a la solapa “Mis pedidos” capturando la solicitud con Burp.
3. Se cambió el parámetro del order_id 1001 por 1002.
4. El servidor devolvió un 200 OK con la información completa del pedido del id 1002.

Impacto en el negocio

- Violación directa de la LFPDPPP (exposición de datos personales).
- Posible suplantación de identidad o estafas si un atacante usa estos datos para ingeniería social.
- Pérdida de confianza de los clientes. Similar al incidente reportado inicialmente por el usuario.

Riesgo	ALTO
CVSS	7.5 · Alta
Vector	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

AUR-02 · Exposición de Información Sensible en Respuestas JSON

MEDIA

Descripción

El endpoint `/api/user/profile` devuelve en la respuesta campos como `email`, `phone_number` y `full_address` del usuario logueado. Sin embargo, en ciertas respuestas de error (ej: cuando se solicita un perfil inexistente), el servidor incluye en el stack trace la cadena de conexión a la base de datos ofuscada y el listado de columnas de la tabla `users`. Aunque no se exponen contraseñas, sí se revela el esquema de la BD.

Impacto

Un atacante podría usar esta info para planificar ataques más avanzados como inyección SQL o para mapear la estructura de datos.

Recomendación inmediata

Deshabilitar el mensaje de error detallado en entornos de producción. Usar respuestas genéricas como "Ocurrió un error interno".

AUR-03 · Falta de Rate Limiting en Inicio de Sesión

MEDIA

Descripción

No existe un límite de intentos fallidos en el formulario de login. Con un diccionario de contraseñas comunes, se pueden realizar 1000 intentos en menos de 5 minutos sin ser bloqueado.

Impacto

Facilitaría un ataque de fuerza bruta para obtener credenciales de clientes o empleados, derivando en toma de cuentas (ATO).



Matriz de riesgo

Alta (AUR-01)	Alto (datos PII)	Riesgo Extremo
Media (AUR-02, AUR-03)	Medio	Riesgo Alto
Baja (AUR-04, AUR-05)	Bajo	Riesgo Moderado



Para reducir los riesgos identificados, se proponen las siguientes acciones clasificadas por prioridad:

PRIORIDAD 1 · INMEDIATA - 48 HORAS

Corregir IDOR (AUR-01): Implementar validación en el backend (capa de lógica de negocio) que compare el user_id de la sesión con el user_id asociado al order_id antes de devolver la información. Usar un ORM que filtre automáticamente por el usuario autenticado. Dependiendo el método creado recomendamos utilizar un Order.findByPk con las comparativas adecuadas.

PRIORIDAD 2 · CORTO PLAZO - 1 SEMANA

AUR-02 y AUR-03: Configurar el archivo de propertys y configuraciones para que DEBUG=false y personalizar los manejadores de errores. Implementar un sistema de bloqueo temporal (ej: 3 intentos fallidos = captcha, 7 = bloqueo 15 min) y añadir rate-limiting por IP (ej: 100 peticiones por minuto).

PRIORIDAD 3 · MEDIANO PLAZO - 1 MES

AUR-04 y AUR-05: Añadir cabeceras de seguridad: Strict-Transport-Security, X-Frame-Options: DENY, X-Content-Type-Options: nosniff. Unificar mensajes de error en login/registro para evitar user enumeration (usar siempre "Usuario o contraseña incorrectos").



Conclusión y cierre

El equipo de NGCSecurity confirma que el incidente reportado por el usuario corresponde a una vulnerabilidad real de tipo IDOR (AUR-01). Afortunadamente, no se encontraron evidencias de que esta haya sido explotada masivamente por terceros, pero el riesgo es latente.

El estado general de seguridad de la aplicación es MODERADO con una tendencia a CRÍTICO si no se corrigen los fallos de autorización. Aurora Market tiene una oportunidad excelente de fortalecer su seguridad implementando las correcciones propuestas, especialmente en la capa de permisos y validación de datos.

OBJETIVO DE REMEDIACIÓN

Desde nuestro punto de vista, con la aplicación de este plan de remediación en los próximos 15 días, la plataforma alcanzaría un nivel de seguridad ACEPTABLE para continuar con su crecimiento.

Agradecemos la confianza depositada en nuestro equipo.

Quedamos a disposición para una sesión de esclarecimiento de dudas o soporte en la implementación de los parches.

NGCSECURITY

Evaluación de Seguridad Ofensiva · Aurora Market